M1.870 - Fundamentos de ciberseguridad

Reto 1: Riesgos, vulnerabilidades y amenazas

1. Contexto Organizativo y Estratégico

AERO-DEFENSE DYNAMICS (ADD) se ha consolidado en la última década como uno de los centros industriales de referencia a nivel nacional en el sector aeroespacial y de defensa, destacando no solo por su excelencia en ingeniería aeronáutica y sistemas de propulsión de precisión, sino por su agresiva estrategia de transformación digital hacia lo que se conoce como "Industria 4.0". Situada en un complejo industrial y de I+D de más de 60.000 metros cuadrados, la compañía gestiona el diseño, ensamblaje y mantenimiento de flota para más de 20 programas de defensa nacionales e internacionales, además de albergar centros de pruebas de alta complejidad.

La misión de ADD trasciende la mera fabricación industrial; busca integrar la simulación avanzada e inteligencia artificial con la cadena de montaje y mantenimiento diario mediante el uso intensivo de datos e IoT industrial. Si bien este avance tecnológico supone una gran ventaja, también ha convertido a la organización en un blanco de alto valor para el ciberespionaje industrial y las Amenazas Persistentes Avanzadas (APT). Estas últimas son infiltraciones altamente sofisticadas diseñadas para evadir las defensas y permanecer ocultas en los sistemas de la empresa durante meses o años, con el fin de robar propiedad intelectual de forma silenciosa y continua. La dirección es plenamente consciente de que un incidente de seguridad, como un ataque de ransomware que cifra los planos de fabricación o una filtración masiva de secretos de defensa, no sólo acarrearía sanciones millonarias e inhabilitación para contratos públicos, sino que podría paralizar la producción y poner en riesgo directo la seguridad nacional.

Recientemente, ADD ha firmado un contrato estratégico con el Ministerio de Defensa para integrarse en la red de fabricantes del nuevo "Sistema de Combate Aéreo de Nueva Generación". Este acuerdo exige que los sistemas de información y de planta de ADD cumplan rigurosamente con el **Esquema Nacional de Seguridad (ENS)** en su categoría Alta y la normativa de protección de Infraestructuras Críticas, elevando los requisitos de conformidad y auditoría a un nivel sin precedentes. **Vuestra labor, como responsables del área de Ciberseguridad, es modelar el sistema para realizar un análisis de riesgos que sirva de base para esta certificación y para el plan director de seguridad.**

2. Infraestructura del Sistema de Información

Para proteger eficazmente el entorno, es imprescindible comprender la anatomía del sistema de información, el cual es un híbrido complejo entre tecnologías de la información (*Information Technology*, IT) y tecnologías de operación industrial (*Operational Technology*, OT).

El núcleo neurálgico de ADD reside en su Centro de Proceso de Datos (CPD) principal, ubicado en el búnker subterráneo del edificio de mando y administración. Este recinto, considerado una sala técnica de acceso altamente restringido, actúa como el cerebro de la institución. En su interior, filas de armarios racks organizan meticulosamente el equipamiento informático. La sala cuenta con un sistema de alimentación ininterrumpida (SAI) de gran capacidad, respaldado por generadores eléctricos diésel de arranque automático. Además, debido al nivel de clasificación de los proyectos, el búnker cuenta con equipos de destrucción de soportes de información certificados militarmente para la eliminación física segura de discos y documentos obsoletos.

La conectividad que da servicio al complejo industrial se basa en una infraestructura de cableado de fibra óptica troncal blindada que une los diferentes edificios (Naves de Ensamblaje, Laboratorios de I+D, Centro de Pruebas). Esta red física soporta una arquitectura lógica segmentada vital para la ciberseguridad. Existe una Red Local (LAN) principal para el tráfico interno, pero esta se subdivide mediante el uso de VLANs para aislar el tráfico crítico: una red exclusiva para robótica y robótica de línea de montaje (OT), otra para la red de videovigilancia de alta definición y una red de gestión fuera de banda para los administradores de sistemas. Además, para proveedores y visitas técnicas, se ofrece una red WiFi segregada que, aunque permite la navegación por Internet, está totalmente aislada de los entornos de diseño y producción. La salida al exterior se realiza a través de una conexión a Internet redundante de alta disponibilidad, protegida por firewalls de nueva generación (NGFW) en alta disponibilidad

3. Activos Tecnológicos y Operativos

Sobre esta infraestructura de red operan los dispositivos que permiten el trabajo diario del personal. En las oficinas de gestión estratégica y compras, el equipo de usuario estándar es el ordenador de sobremesa con sistema operativo Windows 11, desde donde se gestionan pedidos y tareas administrativas. Estos ordenadores cuentan con un antivirus de última generación capaz de detectar cualquier archivo malicioso en el equipo.

Para otros puestos de trabajo la movilidad es clave en la planta de montaje y en las pistas de pruebas; por ello, los ingenieros de campo y mecánicos utilizan equipos portátiles con Linux y teléfonos móviles con un sistema operativo Android fuertemente securizado, lo que les permite consultar planos 3D y telemetría a pie de aeronave de forma ágil y protegida.

Por otro lado, la maquinaria crítica de la planta de mecanizado (como los tornos de control numérico CNC más antiguos) opera sobre versiones legacy de sistemas operativos como Windows XP o Windows 7 Embedded, representando una brecha potencial de riesgo considerable que requiere aislamiento.

En el ámbito de la infraestructura centralizada, ADD ha optado por una arquitectura de virtualización soportada por un clúster de potentes servidores físicos bajo los sistemas operativos Linux y Windows Server. Este entorno aloja un hipervisor VMware sobre el que corren decenas de máquinas virtuales que sustentan todo el ecosistema de software: desde los servidores de bases de datos (Oracle y SQL Server) que custodian las métricas de producción, hasta los servidores de ficheros con planos CAD y normativas de aviación, pasando por el servidor de aplicaciones que ejecuta el PLM/ERP industrial (*Product Lifecycle Management*). Todo este parque tecnológico se complementa con el uso de herramientas ofimáticas estándar para la elaboración de informes y presentaciones del proyecto

La seguridad perimetral y el control de la red se gestionan desde dispositivos específicos de comunicaciones, pero también se ha implementado una Zona Desmilitarizada (DMZ) para publicar servicios hacia el exterior sin comprometer la red interna, como el portal seguro para proveedores de la cadena de suministro.

4. Gestión de la Información y Servicios Esenciales

El valor real de AERO-DEFENSE DYNAMICS no reside en sus máquinas, sino en la información que procesan y los servicios que prestan. El activo primordial son las patentes de diseño y planos de telemetría. La confidencialidad de estos datos es sagrada. Para acceder a ellos, el sistema no se basa en la confianza ciega; requiere que cada usuario interno (ingenieros, operadores, directivos) demuestre quién es. El sistema centralizado verifica la identidad digital del empleado comparando la información introducida con la almacenada en su base de datos de usuarios. No basta con decir quién eres; el sistema debe validar esa afirmación mediante el uso de contraseñas que sólo el usuario debe conocer y que debe renovar periódicamente según la política de seguridad. Los usuarios están identificados de manera única mediante una dirección de correo electrónico corporativo. Se utiliza el correo electrónico como herramienta principal de comunicación cotidiana.

Una vez dentro del sistema, no todos pueden ver todo. Existe un mecanismo lógico que consulta una lista de permisos (RBAC) asociada a cada perfil profesional. Este mecanismo decide si un técnico de mantenimiento puede ver la fórmula de una aleación confidencial (probablemente no) o si un ingeniero jefe puede autorizar una modificación en el software del motor. Estos datos que definen quién puede hacer qué son vitales para evitar fugas de información interna o espionaje industrial.

La capacidad de respuesta táctica de ADD exige la disponibilidad ininterrumpida (24/7/365) de sus servicios informáticos neurálgicos, donde la mínima latencia o interrupción puede paralizar la producción militar. En este nivel de máxima prioridad destaca la plataforma de comunicaciones asíncronas de alta seguridad, una canalización crítica responsable de transmitir notificaciones de control de calidad en tiempo real, alertas de fallos en ensayos de vuelo y órdenes de ingeniería urgentes. La caída de este flujo de datos entre las cuentas corporativas no sólo congelaría la cadena de montaje de defensa, sino que comprometería la coordinación en misiones activas y la seguridad del personal en campo.

Otro pilar de ADD es la capacidad de trabajar en remoto. Ingenieros desplazados en bases militares o directivos en viajes oficiales disponen de un servicio que les permite establecer una conexión segura hacia la red del complejo a través de una VPN con túnel cifrado. Este acceso a distancia es vital para mantener la operativa correcta.

La colaboración con el Ministerio de Defensa y socios internacionales implica el movimiento constante de información. La organización dispone de un servicio dedicado para el intercambio seguro de archivos pesados (SFTP/FTPS), especialmente simulaciones de fluidos y modelos CAD en 3D que, por su enorme tamaño, no pueden enviarse por correo electrónico. Este intercambio debe ser rápido y blindado.

Para mantener el orden en una organización con miles de empleados y dispositivos IoT, existe un servicio de directorio jerárquico (Active Directory/LDAP). Este servicio actúa como una guía centralizada que contiene la información de todos los objetos de la red (usuarios, impresoras industriales, puestos de control) y facilita su administración.

Además, la empresa debe garantizar la integridad y el no repudio en los partes de verificación de vuelo y firmas de proyectos. Para ello, se ha desplegado una Infraestructura de Clave Pública (PKI) para la gestión del ciclo de vida de los certificados digitales. Esta tecnología es la base para la firma electrónica de los certificados de aeronavegabilidad, asegurando que un documento técnico no ha sido alterado desde su aprobación.

5. Protección, Resiliencia y Recuperación

La robustez del sistema se pone a prueba continuamente. Conscientes de que los fallos ocurren y los ciberataques existen, ADD ha implementado una política estricta de salvaguarda. Toda la información crítica, desde los diseños de ingeniería hasta las bases de datos de producción, se duplica periódicamente. Estos conjuntos de datos duplicados se almacenan en un servidor de backup específico y, posteriormente, se replican de forma asíncrona en un almacenamiento en red (SAN) ubicado en un búnker secundario a 50 kilómetros. Esta réplica utiliza discos virtuales con tecnología de inmutabilidad (WORM) para garantizar la recuperación ante un secuestro informático por ransomware.

Sin embargo, restaurar el sistema no es solo cuestión de recuperar los archivos de ingeniería. Un sistema industrial complejo depende de miles de parámetros técnicos: reglas de firewall perimetral, ajustes de rendimiento de las bases de datos, asignación de puertos en los switches de planta y configuraciones del software PLM. Estos datos de configuración del sistema, si se perdieran o fueran alterados maliciosamente, dejarían la cadena de montaje inoperativa o vulnerable, aunque los planos estuvieran a salvo. Por ello, su protección y el control de cambios sobre los mismos es tan crítico como el de la propia información de proyectos.

Cada acción que ocurre en el sistema deja una huella. Desde el inicio de sesión de un operario hasta la modificación de un código de control numérico, el sistema genera registros cronológicos de eventos (Logs). Esta información, consolidada en un sistema SIEM, es fundamental para la forensia digital. Permite a los analistas del SOC (Centro de Operaciones de Seguridad) reconstruir qué pasó, quién lo hizo y cuándo, siendo una pieza clave para la trazabilidad de la cadena de suministro y auditorías de defensa.

Finalmente, la protección de los datos en tránsito y reposo se apoya en el uso de criptografía. Para el acceso seguro a los portales web (intranet corporativa, portal de proveedores), se utilizan certificados SSL/TLS instalados en los servidores web, garantizando que el tráfico navega cifrado. Además, para el transporte físico de material clasificado o copias de seguridad puntuales entre plantas, el personal técnico utiliza discos duros externos cifrados por hardware.

El equipo humano que gestiona esta complejidad incluye no solo a los ingenieros de planta, sino a un departamento de IT/OT robusto. Liderados por el CISO, figuran los administradores de sistemas

y redes, encargados de que los servidores e infraestructura no fallen, y los desarrolladores de software interno. También es frecuente la presencia de personal de proveedores externos y mantenedores de robótica industrial, quienes deben someterse a estrictos controles de acceso físico y lógico para no introducir malware ni vulnerabilidades en la red de producción.

Actividades a realizar

Para realizar las actividades de este reto, utiliza la plantilla de *Google Sheets* disponible en el siguiente enlace:

Análisis de Riesgos UOC

Como el documento es de solo lectura, debes crear una copia en "Mi unidad" de *Google Drive* para poder trabajar en él. Una vez listo, compártelo con tu PDC copiando el enlace en "Reto 1. Enunciado y entrega". Es imprescindible que la copia realizada en la unidad de cada estudiante utilice como nombre del archivo el siguiente formato: **Nombre_Apellido_Reto1**

a) **Activos**. Para cada una de las categorías, selecciona los activos presentes en el sistema de información de AERO-DEFENSE DYNAMICS. El valor entre paréntesis indica el número máximo de activos que puedes seleccionar de cada categoría.

1. [I] Información / Datos (5)
2. [S] Servicios (5)
3. [SW] Software - Aplicaciones informáticas (3)
4. [HW] Hardware - Equipamiento Informático (3)
5. [COM] Redes de comunicaciones (3)
6. [Media] Soporte de información (2)
7. [Key] Claves criptográficas / Secretos (1)
8. [AUX] Equipamiento auxiliar (3)
9. [L] Instalaciones (3)
10. [P] Personal (3)

Para esta actividad te puedes apoyar en el Libro II: Catálogo de Elementos de MAGERIT versión 3.

Registra la actividad en la hoja ***Catalogo_Activos*** de la aplicación **Análisis de Riesgos UOC**.

b) Justificación de Activos Esenciales. Para cada uno de los activos esenciales (información y servicios) seleccionados en la actividad a), selecciona el fragmento del enunciado que justifica tu decisión.

Registra la actividad en la hoja ***Justificacion_Activos*** de la aplicación **Análisis de Riesgos UOC**.

c) Categorización del Sistema según el Esquema Nacional de Seguridad (ENS). Para los activos esenciales (información y servicios) seleccionados en la actividad a), valora el impacto sobre cada una de las dimensiones que supondría la materialización de una amenaza. Una vez realizada la valoración de activos, asigna la categoría al sistema de información de AERO-DEFENSE DYNAMICS que le corresponda de acuerdo al ENS.

Para esta actividad te puedes apoyar en CCN-CERT BP/14 Declaración de Aplicabilidad.

Registra la actividad en la hoja ***Categorizacion_Sistema*** de la aplicación **Análisis de Riesgos UOC**.

d) Amenazas. Selecciona las doce (12) amenazas más relevantes para el sistema de información de AERO-DEFENSE DYNAMICS.

Para esta cuestión te puedes apoyar en el Libro II: Catálogo de Elementos de MAGERIT versión 3.

Registra la actividad en la hoja ***Catalogo_Amenazas*** de la aplicación **Análisis de Riesgos UOC**.

e) Aplicación Amenazas. Determina sobre qué activos tienen más trascendencia las amenazas seleccionadas en la actividad d).

Registra la actividad en la hoja ***Cruce_Activos_Amenazas*** de la aplicación **Análisis de Riesgos UOC**.

f) Análisis de Riesgos. Para cada tupla activo-amenaza resultante de las actividades anteriores, estima la probabilidad de que la amenaza se materialice sobre el activo y el impacto que esto supondría.

Registra la actividad en la hoja ***Analisis_Riesgo*** de la aplicación **Análisis de Riesgos UOC**.

g) Medidas de Seguridad. Selecciona diez (10) medidas de seguridad del anexo II del Esquema Nacional de Seguridad (ENS), no mencionadas en el enunciado, cuya aplicación minimizaría el riesgo residual que soporta el sistema de información de AERO-DEFENSE DYNAMICS. Para cada medida de seguridad, además de clasificarla, justifica su elección (máximo 150 palabras por justificación).

Para esta cuestión te puedes apoyar en anexo II del Esquema Nacional de Seguridad (ENS).

Registra la actividad en la hoja ***Medidas_Seguridad*** de la aplicación **Análisis de Riesgos UOC**.

h) Conclusiones. Redacta tus conclusiones y reflexiones finales sobre el proceso de análisis y gestión de riesgos. Entre otros, debes abordar aspectos como la importancia del análisis de riesgos en sistemas de información, sus implicaciones, las limitaciones de la herramienta utilizada y la aplicabilidad de la metodología MAGERIT.

Registra la actividad en la hoja ***Conclusiones*** de la aplicación **Análisis de Riesgos UOC**.

Criterios de evaluación

- En esta actividad se deberán escribir las respuestas siguiendo el formato establecido en la plantilla de respuestas proporcionada junto al enunciado del reto. En el apartado de entrega de este reto hay disponible una rúbrica que indica los criterios de corrección de esta actividad.

- Este Reto es un trabajo personal e individual, realizado por el/la estudiante para este curso y no se admitirán copias totales o parciales de contenidos. Tras verificarlos, los trabajos que sean considerados copias serán suspendidos y se informará a la Dirección de los Estudios para que tome las medidas oportunas especificadas en la normativa de la UOC sobre plagio y copias (consultar la guía docente al respecto).

- Para la resolución de las actividades del reto no está permitido el uso de herramientas de inteligencia artificial. En el plan docente y en la web sobre integridad académica y plagio de la UOC encontraréis información sobre qué se considera conducta irregular en la evaluación y las consecuencias que puede tener.

- La entrega del presente reto por parte del/de la estudiante implica que ha leído y acepta las condiciones y que el reto cumple con los criterios anteriormente expuestos en cuanto a privacidad y autoría.

Formatos y fechas de entrega

- La entrega se realizará en el apartado específico del aula, “Reto 1. Enunciado y entrega”, copiando el enlace al documento de *Google Sheet* donde el alumno haya resuelto las actividades. Es obligatorio que el documento que presente cada estudiante utilice como nombre del archivo el siguiente formato: **Nombre_Apellido_Reto1**

- Es responsabilidad del alumno garantizar que el enlace compartido sea accesible al concluir el plazo de entrega. De lo contrario, la PEC se considerará no presentada.

- El plazo límite para realizar la entrega de este reto se indica en el aula virtual.